Rapport stratégique : intrusion INC-2026-0302

Pour la direction d'Helios Energy (entreprise fictive). Version du 2026-10-06. Document d'exercice : aucune donnée n'est réelle.

1. En bref

Pendant environ cinq jours (du 2 au 7 mars 2026 : **ce sont les bornes de ce que le dossier a observé, pas le début ni la fin certains**), un intrus a exécuté des commandes sur un poste de la comptabilité, s'est ensuite manifesté sur un serveur et sur le contrôleur de domaine, a fait sortir environ **2,5 Go de données vers l'extérieur** et a effacé des traces. **Nous ne savons pas** quelles données sont sorties, si l'intrus est encore présent, ni qui il est. Il n'est pas possible, avec les éléments reçus, de désigner un auteur : **le groupe reste non attribué**.

2. Ce que nous savons, ce que nous ne savons pas

Établi par les journaux	Non démontré ou inconnu
Une commande masquée lancée sur le poste comptabilite-07	Le courriel d'origine (aucun journal de messagerie)
Un programme téléchargé (421 376 octets), une tâche planifiée créée	Ce que le programme fait réellement (aucun échantillon fourni)
Un accès à la mémoire des identifiants sur le contrôleur de domaine dc-01	Si des identifiants ont réellement été volés et réutilisés
Un compte créé puis supprimé ; un accès à distance par ce compte	Comment l'intrus est passé d'un poste à l'autre ; l'origine de l'accès à distance
Un volume de 2 469 135 790 octets sorti en clair depuis dc-01	Le contenu, le caractère personnel ou confidentiel des données
Le journal de sécurité du poste d'entrée effacé le 7 mars	La présence actuelle de l'intrus

Le dossier comporte **21 incohérences** (par exemple un compte utilisé 36 heures avant sa création). Nous les signalons sans les « corriger » : elles limitent la fiabilité de la chronologie.

3. Conséquences pour l'activité

- **Impact observé** : intégrité du poste d'entrée compromise (exécution non autorisée, traces effacées) ; sortie de données depuis un serveur critique ; création d'un compte non autorisé sur l'annuaire.
- **Impact potentiel** : si les identifiants ont été volés, prise de contrôle de l'annuaire (donc de tout le SI) ; si des données personnelles ou sensibles sont sorties, obligations de notification et atteinte à la réputation ; extorsion possible (hypothèse, aucune demande observée).
- **Rien n'indique** une atteinte à des systèmes industriels ou à la fourniture d'énergie : aucun artefact ne le suggère, et rien ne permet non plus de l'exclure sans enquête.

4. Risques principaux

Risque	Gravité estimée	Pourquoi
Intrus toujours présent (persistance, comptes)	Élevée	Effacement de journal le 7 mars, tâche planifiée créée
Compromission de l'annuaire	Élevée si confirmée	Accès à la mémoire des identifiants sur dc-01
Fuite de données	Inconnue, potentiellement élevée	2,5 Go sortis, contenu inconnu
Non-conformité réglementaire	À qualifier	Dépend du statut OIV/SIIV et de la présence de données personnelles (voir la note ANSSI)

5. Niveau de confiance et limites

Confiance **élevée** dans les faits observés par plusieurs lignes de journal (téléchargement, accès LSASS, sortie de volume, effacement de journal). Confiance **faible** dans les capacités de l'outil (aucun échantillon) et dans l'enchaînement exact des étapes entre les hôtes. Confiance **élevée** dans le fait que l'auteur ne peut pas être désigné. Les cotes de fiabilité des sources ne dépassent pas « C » (assez fiable) et aucune information n'est confirmée par une source indépendante.

6. Décisions demandées et priorités

Priorité	Décision	Lien avec l'observation
P0 (immédiat)	Confirmer si l'intrus est présent : chasser les traces de la tâche `MicrosoftEdgeUpdateTaskMachine` et du compte `svc-backup-temp` ; isoler et conserver une image de comptabilite-07	Tâche créée le 2 mars ; effacement de journal le 7 mars
P0	Décider du réexamen des comptes privilégiés et des secrets de l'annuaire si l'extraction d'identifiants est confirmée	Accès LSASS sur dc-01
P1 (sous quelques jours)	Qualifier les données sorties (analyse du trafic et des fichiers) ; bloquer le trafic sortant en clair depuis les serveurs critiques	2,5 Go vers 203.0.113.28:8080
P1	Désigner la personne qui qualifie l'obligation de notification (ANSSI, CNIL) : voir la note réglementaire	Statut et données personnelles inconnus
P2 (trimestre)	Journalisation centralisée et protégée contre l'effacement ; segmentation poste-serveur-annuaire	Journal effacé ; mouvement latéral inconnu
P2	Durcir le poste de travail (macros, PowerShell encodé : règles de détection livrées)	Chaîne d'entrée observée

7. Recommandations pérennes et proportionnées

1. **Détecter ce qui a été observé.** 15 règles de détection ont été écrites et testées localement (11 fondées sur les journaux) : à déployer après revue par le SOC. Elles s'appuient sur l'infrastructure de supervision existante.
2. **Réduire la surface** : restreindre les macros Office venant d'Internet, journaliser PowerShell (blocs de script), restreindre l'accès à distance aux comptes de service. Mesures peu coûteuses, durables.
3. **Protéger les journaux** : envoi vers un collecteur à écriture seule, rétention proportionnée aux besoins d'enquête.
4. **Éco-responsabilité.** Cette mission a **réutilisé l'infrastructure existante** (aucun serveur ni service nouveau déployé) ; le conteneur de test créé a été supprimé ; les données de test sont étiquetées pour être retirées ; les alertes de test générées dans la supervision sont identifiables (groupe `helios_challenge`) et leur retrait nécessite un accord explicite (aucune suppression n'a été faite). **Aucune économie d'énergie ou de coût n'est chiffrée : elle n'a pas été mesurée.** Pour la suite, privilégier la mutualisation des outils de supervision et une conservation des journaux limitée à l'utile.

8. Ce qu'il faut retenir

Les faits établis suffisent pour **agir** (chasser, isoler, qualifier les données sorties, examiner la notification). Ils ne suffisent pas pour **accuser** : aucune attribution n'est justifiée. Les points d'incertitude sont listés dans le rapport tactique ; ils déterminent les enquêtes complémentaires à lancer.